

INTRODUCTION AU TEST D'INTRUSION

Synthèse de cadrage

Projet final · Conduire une mission sur dossier



Contexte de mission

Client : Coopérative Sahel-Vert.
Prestataire : Cabinet Harmattan.
Période de mission : du 2 au 19 juin 2026.
Cheffe de mission : Mariam Diallo.
Testeur référent : Yao Kouassi.
Contact client technique : Ibrahim Sanou.
Contact client juridique : Rokia Bamba.
Tous les horodatages du dossier sont en UTC.



Objectifs validés avant démarrage

- ◆ confirmer le périmètre public utile à la mission ;
- ◆ relever les écarts de surface d'exposition par rapport aux services attendus ;
- ◆ qualifier les constats du scanner et des notes web ;
- ◆ préparer un rapport factuel, sans extrapolation ni accusation.



Périmètre applicatif et technique

FQDN	RÔLE	TYPE DE VÉRIFICATION AUTORISÉ	STATUT
www.sahel-vert.example	site vitrine	lecture OSINT, en-têtes, disponibilité	en périmètre informatif
portail.sahel-vert.example	portail adhérents et exports métiers	tests web avec comptes de démonstration, revue de code, lecture des journaux	en périmètre applicatif
vpn.sahel-vert.example	portail VPN du personnel	lecture des bannières et des journaux, sans tentative de connexion supplémentaire	en périmètre technique
stock.sahel-vert.example	extranet logistique	lecture des en-têtes, cartographie réseau, revue des journaux de mission	en périmètre technique
mail.sahel-vert.example	messagerie coopérative	relevé d'exposition des ports, sans collecte de boîtes	en périmètre technique

FQDN	RÔLE	TYPE DE VÉRIFICATION AUTORISÉ	STATUT
paie.sahel-vert.example	application de paie d'un tiers	simple présence au DNS ; aucune interaction applicative	hors périmètre applicatif



Services attendus selon le client

HÔTE	SERVICES ATTENDUS	COMMENTAIRE
www.sahel-vert.example	80, 443	vitrine publique simple
portail.sahel-vert.example	443	accès web via HTTPS uniquement
vpn.sahel-vert.example	443, 1194	portail et tunnel VPN
mail.sahel-vert.example	25, 465, 587, 993	service de messagerie public
stock.sahel-vert.example	22, 443	extranet logistique et maintenance distante contrôlée
paie.sahel-vert.example	443	application tiers, exclue des validations actives
api.sahel-vert.example	443	API publique de consolidation pour le portail
srv-relai.sahel-vert.example	22	relais technique interne supervisé
srv-journal.sahel-vert.example	22, 6514	nœud interne de collecte de journaux



Fenêtres autorisées

- ◆ reconnaissance passive : 2 au 19 juin 2026, 08:00 à 18:00 UTC ;
- ◆ scans modérés et validations web : 09:00 à 17:00 UTC ;
- ◆ toute activité hors fenêtre doit être journalisée comme écart, même si elle reste bénigne ;
- ◆ aucune action n'est menée les dimanches sans accord écrit supplémentaire.



Règles d'engagement

IDENTIFIANT	ACTION	CLAUSE
R01	Consolider des sources OSINT publiques	autorisé
R02	Lancer un scan TCP modéré sur les FQDN publics listés	autorisé pendant la fenêtre prévue
R03	Vérifier un contrôle d'accès avec des comptes de démonstration et une preuve minimale	autorisé si la donnée affichée reste anonymisée
R04	Télécharger un extrait de preuve déjà exposé dans le portail pour le joindre au rapport	autorisé si le volume reste minimal
R05	Saturer un service, forcer des authentifications ou déposer un fichier exécutable	jamais

IDENTIFIANT	ACTION	CLAUSE
R06	Copier des données de paie ou d'un tiers hors des captures minimales convenues	jamais



Exclusions explicites

- ◆ aucune simulation de déni de service ;
- ◆ aucune modification métier volontaire ;
- ◆ aucune réutilisation d'un compte réel hors des comptes de démonstration fournis ;
- ◆ aucune validation sur des actifs découverts en dehors des FQDN listés ;
- ◆ aucune exportation de données de paie en dehors d'une preuve anonymisée.



Gestion des preuves

- ◆ conserver la preuve minimale ;
- ◆ noter pour chaque preuve le fichier source, l'heure UTC et le lien avec le constat ;
- ◆ distinguer constat, faux positif et hypothèse ;
- ◆ journaliser tout nettoyage à prévoir avant clôture.



Comptes de démonstration et données

- ◆ les validations applicatives autorisées utilisent uniquement des comptes de démonstration ;
- ◆ toute preuve téléchargée doit rester minimale et anonymisée ;
- ◆ aucun export de paie réelle n'est autorisé ;
- ◆ les captures destinées au rapport sont chiffrées pendant la mission ;
- ◆ les comptes de démonstration du stock et du portail doivent être désactivés avant clôture ;



Conditions d'arrêt immédiat

- ◆ arrêt si une action menace la disponibilité d'un service ;
- ◆ arrêt si une donnée non prévue apparaît hors anonymisation convenue ;
- ◆ arrêt si un actif non listé semble exposé et nécessite une autorisation supplémentaire ;
- ◆ arrêt si le client demande un gel de production exceptionnel.



Livrables attendus

- 1 une synthèse des constats confirmés ;
- 2 une priorisation défendable à partir de la grille de risque ;
- 3 un résumé exécutif factuel ;
- 4 un modèle de rapport complété sans inventer de preuve.



Communication et escalade

- ◆ les écarts au cadrage doivent être signalés le jour même à Ibrahim Sanou ;
- ◆ tout doute sur une preuve sensible remonte aussi à Rokia Bamba avant intégration au rapport ;
- ◆ Mariam Diallo valide la formulation finale des constats confirmés ;
- ◆ Yao Kouassi garde une piste de vérification reproductible pour chaque pièce citée.



Lecture des pièces du dossier

- ◆ le scan réseau XML consolide un relevé ciblé sur les ports les plus utiles à la mission ;
- ◆ le tableau de constats mélange faux positif, constat confirmé et hypothèse ;
- ◆ l'historique web contient du bruit de navigation légitime autour de quelques preuves utiles ;
- ◆ le journal de mission sert aussi à vérifier l'horaire des écarts et l'état du nettoyage.



Rappels de langage

- ◆ un constat est un fait démontré par une preuve suffisante ;
- ◆ une hypothèse reste à confirmer par une deuxième preuve indépendante ;
- ◆ un faux positif est un signal infirmé par les pièces du dossier.



Clôture attendue

La mission se termine par une restitution factuelle, la liste des nettoyages restants et la préparation d'un re-test. Toute ambiguïté doit être signalée comme telle dans le rapport.



Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite.